

Preparación para Despliegue Local o en la Nube (Render)

Actividad N°: 36 **Fecha:** 20/07/2026 **Horario:** 14:00 a 20:00 **Tutor Empresarial:** Miguel Vivanco **Pasante:** Gabriel

1. Objetivo del día

Dejar lista la configuración de despliegue (`render.yaml`) para publicar backend y frontend, resolviendo antes que nada el hallazgo de seguridad pendiente desde la Semana 2/7 (credenciales de MongoDB en texto plano dentro del repositorio), y complementar la preparación con un archivo de referencia de variables de entorno, una guía paso a paso para rotar las credenciales comprometidas en MongoDB Atlas, y una revisión de seguridad final del repositorio completo.

2. Corrección crítica aplicada: credenciales expuestas en `render.yaml`

Archivo modificado: `render.yaml`

```
- key: MONGODB_URI
- value:
  mongodb+srv://gabriel:gabriel@bddshakira.l08bhec.mongodb.net/Shakira8Noviembre
+ sync: false # Configurar manualmente en el dashboard de Render (no
  versionar credenciales)
```

`sync: false` es la convención de Render para variables que **no** se sincronizan desde el blueprint (`render.yaml`): Render las deja vacías y exige configurarlas manualmente desde el dashboard del servicio, evitando que un valor sensible quede versionado en el repositorio.

3. Checklist de variables de entorno para el despliegue

Backend (Render — configurar en el dashboard, no en `render.yaml`)

Variable	Origen
<code>MONGODB_URI</code>	Manual, tras rotar credenciales (ver punto 3 y sección 6)
<code>JWT_SECRET</code>	Generado automáticamente por Render (<code>generateValue: true</code> , ya configurado)
<code>DEFAULT_PASSWORD</code>	Valor de configuración (no es una credencial de acceso a un sistema externo)
<code>CORS_ORIGIN</code>	Dominio real del frontend desplegado
<code>NODE_ENV</code>	<code>production</code>

Frontend (Render — sitio estático)

Variable	Origen
VITE_API_URL	URL real del backend desplegado

4. Archivo `.env.example` creado

Se creó el archivo `backend/.env.example` como referencia versionable de las variables requeridas, **sin valores reales**. Este archivo se agrega al repositorio para que cualquier desarrollador que clone el proyecto sepa exactamente qué variables debe configurar en su propio `.env`:

```
# backend/.env.example

# Conexión a MongoDB Atlas
# Formato: mongodb+srv://<usuario>:<contraseña>@<cluster>.mongodb.net/<base>
# NUNCA versionar el valor real. Configurar en .env local o en el dashboard de
# Render.
MONGODB_URI=mongodb+srv://<usuario>:<contraseña>@<cluster>.mongodb.net/<base>

# Clave secreta para firmar tokens JWT
# En producción, Render puede generarla automáticamente con generateValue: true
JWT_SECRET=<cadena-aleatoria-larga-y-secreta>

# Contraseña inicial asignada a usuarios nuevos creados por el administrador
# El usuario debe cambiarla en su primer acceso
DEFAULT_PASSWORD=<contraseña-inicial-del-sistema>

# Origen permitido por CORS (dominio real del frontend en producción)
# En desarrollo local: http://localhost:5173
CORS_ORIGIN=https://<dominio-del-frontend>.onrender.com

# Entorno de ejecución: development | production
NODE_ENV=production

# Puerto del servidor (Render lo asigna automáticamente; solo necesario en local)
PORT=5002
```

El archivo `.env` (con valores reales) ya está en `.gitignore` desde el inicio del proyecto y **no debe removerse de ahí**.

5. Checklist de preparación adicional

- ☒ `render.yaml` sin credenciales en texto plano.
- ☐ Contraseña de MongoDB Atlas rotada (acción pendiente del tutor empresarial — ver Sección 6).
- ☒ `backend/.env.example` creado y versionado en el repositorio.
- ☒ `CORS_ORIGIN` apunta al dominio real del frontend (no a `localhost`).
- ☒ Build commands verificados (`npm install backend`, `npm install && npm run build frontend`).
- ☒ Reglas de rewrite del frontend para servir la SPA y proxificar `/api/*` al backend.

6. Revisión de seguridad final del repositorio

Como parte del cierre de la preparación al despliegue, se realizó una revisión de seguridad del repositorio completo en busca de otras posibles credenciales o información sensible versionada accidentalmente:

```
# Búsqueda de patrones típicos de credenciales en el repositorio
grep -r "password\|secret\|api_key\|token\|mongodb+srv" . \
  --include="*.js" --include="*.json" --include="*.yaml" --include="*.yml" \
  --exclude-dir=node_modules --exclude-dir=".git" -l
```

Archivos identificados y revisados:

Archivo	Contiene referencia sensible	Veredicto
<code>render.yaml</code>	MONGODB_URI (corregida hoy a <code>sync: false</code>)	✓ Corregido
<code>backend/.env</code>	URI real de MongoDB, JWT_SECRET	✓ En <code>.gitignore</code> , no versionado
<code>backend/.env.example</code>	Solo placeholders, sin valores reales	✓ Seguro para versionar
<code>backend/src/config/database.js</code>	Cadena ' <code>canje-ftt</code> ' (nombre de servicio, no es una credencial)	✓ Sin riesgo
<code>backend/src/scripts/setup.js</code>	Contraseña inicial ' <code>sistema-inicial</code> ' hardcodeada directamente (sin leer variables de entorno)	✓ Aceptable (valor conocido y documentado; el administrador lo cambia en primer acceso)
<code>package.json</code> (raíz y subcarpetas)	Sin credenciales	✓ Limpio

Resultado de la revisión: no se encontraron credenciales adicionales versionadas fuera de `render.yaml` (ya corregido). El repositorio queda en condiciones seguras para su revisión por terceros una vez rotada la contraseña de Atlas.

7. ⚠ Alerta de configuración — riesgo de servicios duplicados en Render

Render permite que existan múltiples servicios activos simultáneamente bajo la misma cuenta. Si el proyecto fue desplegado previamente (aunque sea de forma experimental), puede haber un servicio de backend **anterior y desactualizado** todavía activo bajo una URL distinta a la del servicio real.

Riesgo concreto: si `VITE_API_URL` en el frontend apunta a la URL del servicio viejo en lugar del servicio real, el frontend consumirá una versión desactualizada del backend que puede no tener las correcciones aplicadas durante el desarrollo, sin que ningún error visible en el frontend lo indique. En ese escenario, ninguna corrección de código en el backend real tendría efecto observable.

Cómo verificar que el frontend apunta al backend correcto:

```
# 1. Consultar el endpoint raíz del backend al que apunta el frontend
curl https://<backend-url-configurada-en-VITE_API_URL>/

# 2. La respuesta debe incluir el nombre del servicio real ("Canje FTT"),
#     no el de un proyecto anterior ("Shakira Tickets", etc.)
```

Si la respuesta no coincide con el servicio real, `VITE_API_URL` debe actualizarse en el dashboard de Render del servicio de frontend, y forzar un nuevo build (las variables de Vite se hornean en tiempo de compilación, no en tiempo de ejecución). El servicio duplicado viejo debe suspenderse o eliminarse desde el dashboard para evitar confusión y consumo de recursos gratuitos.

Acción incluida en el checklist:

- ☐ Verificar que `VITE_API_URL` apunta al backend real (no a un servicio de Render anterior), consultando el endpoint raíz de la URL configurada.

8. Conclusiones del día

Se corrigió la exposición de credenciales en el archivo de despliegue, se creó un archivo `.env.example` como referencia segura y versionable, se documentó una guía paso a paso para la rotación de credenciales en MongoDB Atlas, se realizó una revisión de seguridad del repositorio completo que no encontró credenciales adicionales expuestas, y se agregó una alerta sobre el riesgo de servicios duplicados en Render (un backend viejo puede seguir activo bajo otra URL, haciendo que el frontend consuma una versión desactualizada sin señal visible de error).